Cloudflare Security Runbook

Free plan | Last updated April 2026

Overview

This runbook documents the Cloudflare security configuration deployed for. It covers one rate limiting rule, four custom WAF rules, and several global toggles. All configurations are compatible with the Cloudflare Free plan.

Together, these rules defend against credential stuffing on the /admin login, vulnerability scanners, common injection attacks, and background scan traffic. The setup uses 4 of 5 available custom rule slots, leaving room for one tuning rule in the future.

Threats addressed

- Credential stuffing and brute force attacks against the admin login
- Vulnerability scanners and reconnaissance tools
- OWASP Top 10 injection attacks (SQLi, XSS, path traversal, RCE)
- Background scan traffic targeting WordPress, phpMyAdmin, .env files, and similar
- Generic bots and scrapers (handled by Bot Fight Mode)

Coverage limitations

The Free plan does not include the full OWASP Core Ruleset, Bot Management, or API Shield. The injection rule below is a crude pattern-matching backstop, not a true WAF. For a production application handling user data or payments, upgrading to Pro ($25/mo) unlocks the Cloudflare Managed Ruleset, which is a significant improvement for OWASP coverage.

Rate Limiting Rule

RL-1: Rate limit /admin login attempts

Caps login attempts at 5 per 10 seconds per IP, then blocks the offender for 10 minutes. This is the single highest-ROI control against credential stuffing on the Free plan.

Name	Rate limit /admin login attempts
Expression	`(http.request.uri.path contains "/admin" and http.request.method eq "POST")`
Characteristics	IP
Threshold	5 requests per 10 seconds
Action	Block
Block duration	10 minutes
Slot used	1 of 1 Rate Limiting rules

Custom WAF Rules

All four rules below live under Security → Security rules → Custom rules in the Cloudflare dashboard.

CR-1: Challenge admin area

Forces every request to the admin area to solve a Cloudflare Managed Challenge. Real users pass silently in their browser; headless bots and scripts fail. Combined with RL-1, this is your credential stuffing wall.

Name	Challenge admin area
Expression	`(http.request.uri.path contains "/admin")`
Action	Managed Challenge

CR-2: Block scanners and empty UAs

Blocks the loudest 80% of vulnerability scanners by user-agent string, plus any request with an empty user-agent (almost always a script or curl). Real browsers always send a UA, so false positives are essentially zero.

Name	Block scanners and empty UAs

Expression:

```
(http.user_agent eq "") or
(lower(http.user_agent) contains "nikto") or
(lower(http.user_agent) contains "sqlmap") or
(lower(http.user_agent) contains "nmap") or
(lower(http.user_agent) contains "masscan") or
(lower(http.user_agent) contains "zgrab") or
(lower(http.user_agent) contains "acunetix") or
(lower(http.user_agent) contains "nessus") or
(lower(http.user_agent) contains "wpscan")
```

Action: Block

CR-3: Block injection patterns

Crude backstop for OWASP injection attacks. Catches obvious SQL injection, XSS, path traversal, and RCE patterns when they appear in URL query strings. Not a substitute for the full Managed Ruleset, but it stops drive-by scanners cold.

Name	Block injection patterns

Expression:

```
(lower(http.request.uri.query) contains "union select") or
(lower(http.request.uri.query) contains "../") or
(lower(http.request.uri.query) contains "<script") or
(lower(http.request.uri.query) contains "/etc/passwd") or
(lower(http.request.uri.query) contains "base64_decode") or
(lower(http.request.uri.query) contains "concat(") or
(lower(http.request.uri.query) contains "javascript:") or
(lower(http.request.uri.query) contains "onerror=") or
(lower(http.request.uri.query) contains "onload=")
```

Action: Block

CR-4: Block scanner paths

Catches the constant background scan traffic from botnets looking for exposed config files, leaked git repos, AWS credentials, and unpatched WordPress / phpMyAdmin / Exchange installs. None of these paths exist on a normal app, so blocking them is free signal.

WARNING: If you ever migrate to WordPress, remove the /wp-admin, /wp-login, and /xmlrpc.php clauses or you will lock yourself out of your own admin.

Name	Block scanner paths

Expression:

```
(http.request.uri.path contains "/.env") or
(http.request.uri.path contains "/.git") or
(http.request.uri.path contains "/.aws") or
(http.request.uri.path contains "/wp-admin") or
(http.request.uri.path contains "/wp-login") or
(http.request.uri.path contains "/phpmyadmin") or
(http.request.uri.path contains "/xmlrpc.php") or
(http.request.uri.path contains "/owa/") or
(http.request.uri.path contains "/autodiscover")
```

Action: Block

Global Toggles

These are simple on/off settings that complement the rules above.

Bot Fight Mode

Path: Security → Bots (or Security → Settings) | State: ON

Cloudflare's free, automatic bot challenger. Replaces the dedicated 'block bad bots' custom rule we couldn't build because Free plan no longer exposes cf.client.bot or cf.threat_score in custom rules.

Security Level

Path: Security → Settings | State: High

Cloudflare's catch-all reputation filter. 'High' challenges any visitor with even a moderate threat history.

Always Use HTTPS

Path: SSL/TLS → Edge Certificates | State: ON

Forces all HTTP requests to upgrade to HTTPS at the edge. Prevents protocol-downgrade attacks and accidental cleartext.

Minimum TLS Version

Path: SSL/TLS → Edge Certificates | State: TLS 1.2

Refuses connections from clients using deprecated TLS 1.0 or 1.1. Modern browsers all support 1.2+.

Email Address Obfuscation + Hotlink Protection

Path: Scrape Shield | State: Both ON

Free wins. Email obfuscation hides mailto: links from scrapers; hotlink protection prevents other sites from embedding your images.

Under Attack Mode

Path: Security → Settings | State: OFF (break-glass only)

Do not enable in normal operation. This presents an interstitial challenge to every visitor and is intended only for active L7 DDoS incidents. Toggle on, wait for the attack to subside, toggle off.

Operational Notes

Monitoring

Check Security → Events weekly to see what each rule is catching. If a rule is blocking zero traffic for 30 days, consider replacing it with a more targeted control. If a rule is catching legitimate traffic, refine the expression rather than disabling it.

Tuning the open custom rule slot

Free plan allows 5 custom rules; this runbook uses 4. The remaining slot is reserved for tuning. Common uses:

- Geo block: challenge or block traffic from countries you do not serve
- ASN block: block known abusive cloud or VPN ASNs
- Path-specific allow: exempt a specific endpoint from a broader rule
- Honeypot: block any IP that hits a path that should never be requested

If you accidentally lock yourself out

If a rule blocks your own traffic, you can still reach the Cloudflare dashboard from any device because the dashboard runs on dash.cloudflare.com. Log in, go to Security → Security rules, and either disable the offending rule with its toggle or edit its expression. Changes propagate globally within 30 seconds.

Upgrade triggers

Consider upgrading from Free to Pro ($25/mo) when any of the following becomes true:

- The application starts handling personally identifiable information or payments
- You need the full Cloudflare Managed Ruleset for OWASP coverage
- You hit the 5 custom rules / 1 rate limiting rule ceiling
- You want WAF analytics with payload inspection

Upgrade triggers (Business / Enterprise)

- Bot Management (true ML-driven bot scoring) requires Enterprise
- API Shield, mTLS, and JWT validation require Enterprise
- Advanced Rate Limiting (more than 1 rule, granular characteristics) requires Business+

Quick Reference

ID	Rule Name	Action	Protects Against
RL-1	Rate limit /admin login attempts	Block 10 min	Credential stuffing
CR-1	Challenge admin area	Managed Challenge	Brute force, bots
CR-2	Block scanners and empty UAs	Block	Vuln scanners
CR-3	Block injection patterns	Block	SQLi, XSS, RCE
CR-4	Block scanner paths	Block	Recon, exposed config

End of runbook.